STATEMENT OF WORK (SOW)

Project Scope Document

PDF Vault & Digital Asset Storage System Implementation

Document ID	SOW-PDFV-2026-V1	**Effective Date**	October 20, 2026
Project Title	PDF Vault Enterprise Platform Implementation	**Version**	1.0.0 (Baseline)
Client Organization	Enterprise Client Group	**Delivery Partner**	Enterprise Systems Engineering
Contract Reference	MSA-2026-PDFV-001	**Target Completion**	8 Weeks from Project Inception

1. Project Context & Objectives

This Scope Document (Statement of Work - SOW) establishes the formal contractual boundary of all engineering deliverables, work packages, architectural components, operational assumptions, and exclusions for the PDF Vault & Digital Asset Storage System.

The objective of this engagement is to design, develop, test, and deploy a secure, multi-tenant web application that solves enterprise digital asset chaos by delivering robust PDF management, image asset taxonomy, binary file inspection, Scrypt-based identity management, and tiered usage governance.

> **Contractual Scope Boundary**
>
> Any features, integrations, or operational activities not explicitly enumerated within Section 2 ('In-Scope Work Packages') are strictly deemed Out-of-Scope (Section 3) and will require an authorized Change Order.

2. In-Scope Work Packages & Technical Deliverables

The development engagement is partitioned into seven distinct, measurable work packages (WPs):

2.1 Work Package 1: Architecture, Configuration & Backend Core

- **WP1.1 - Application Framework:** Setup and initialization of a Python 3.12+ FastAPI application utilizing asynchronous route handlers, Pydantic v2 schemas, and lifespan context managers.
- **WP1.2 - Centralized Configuration:** Implementation of `pydantic-settings` BaseSettings loading environment configurations from `.env` (application name, API prefixes, storage paths, CORS origins, upload limits, and JWT secrets).
- **WP1.3 - Security Middleware:** Configuration of FastAPI CORSMiddleware supporting secure origin whitelisting (`http://localhost:5173`, `http://localhost:5174`, etc.), credentials propagation, and HTTP method restrictions.
- **WP1.4 - System Probes:** Implementation of root (`/`) and health check (`/api/v1/health`) endpoints providing service status, uptime confirmation, and automated OpenAPI documentation (`/docs`).

2.2 Work Package 2: Identity, Access Management & Tenancy Isolation

- **WP2.1 - User Registration Service:** Creation of `/api/v1/auth/register` with validation for unique username (3-80 chars) and unique lowercase email, returning HTTP 409 on collision.
- **WP2.2 - Scrypt Cryptographic Hashing:** Implementation of `hash_password()` using `hashlib.scrypt` with 16-byte cryptographically secure random salts (N=16384, r=8, p=1, dklen=64) formatted as `scrypt${salt}${digest}`.
- **WP2.3 - Timing-Safe Verification:** Implementation of `verify_password()` utilizing `hmac.compare_digest` to eliminate side-channel timing attack vectors during authentication.
- **WP2.4 - Stateless Token Emission:** Implementation of `create_token()` generating HMAC-SHA256 signed bearer tokens with embedded subject (`sub`) and expiration claims (`exp`).
- **WP2.5 - Dependency Injection (`get_current_user`):** FastAPI dependency parsing Bearer tokens via `OAuth2PasswordBearer`, validating signature against secret, checking expiration, and retrieving active User object.
- **WP2.6 - User Profile Retrieval:** Creation of `/api/v1/auth/me` returning sanitized user identity records.

2.3 Work Package 3: Document Vault & PDF Processing Engine

- **WP3.1 - Folder Taxonomy Engine:** Endpoints for folder creation (`POST /folders`), alphabetical listing (`GET /folders`), and deletion (`DELETE /folders/{id}`).
- **WP3.2 - Safe Folder Unlinking:** Upon folder deletion, contained documents have their `folder_id` atomically reset to NULL, preventing accidental loss of physical files.
- **WP3.3 - True Binary Signature Inspection:** Mandatory inspection of the initial 5 bytes of every uploaded file stream. Files lacking the `%PDF-` byte header are rejected immediately with HTTP 415.

- **WP3.4 - Streaming Upload with Memory Guard:** Asynchronous chunked reading (1MB buffer) with hard ceiling limit (25MB default) to prevent denial-of-service memory exhaustion.
- **WP3.5 - UUID Storage Namespace:** Physical storage files are written to disk under sanitized hex UUIDs (`uuid4().hex.pdf`), eradicating directory traversal and filename collision vulnerabilities.
- **WP3.6 - Filtered Search & Listing:** Query endpoint supporting multi-parameter filtering: active user tenancy, folder identifier, and case-insensitive substring searching (`ilike`).
- **WP3.7 - Binary Download Stream:** Serving files via `FileResponse` with MIME type `application/pdf` and content disposition header preserving original user filename.
- **WP3.8 - Atomic Deletion & Disk Rollback:** Complete removal of database records with corresponding filesystem unlinking. Rollback exception handlers remove orphan files if database writes fail.

2.4 Work Package 4: Digital Image Asset Studio

- **WP4.1 - Category Management:** Independent image categorization module supporting category creation, listing, and cascading deletion.
- **WP4.2 - Strict Multi-Format Verification:** Validation restricting uploads strictly to approved image MIME types (`image/jpeg`, `image/png`, `image/gif`, `image/webp`, `image/bmp`) and matching extensions.
- **WP4.3 - Image Streaming & Previewing:** Dedicated endpoint `/api/v1/images/{id}/file` streaming binary image streams directly to browser clients for real-time blob rendering.
- **WP4.4 - Category Cascading Deletion:** Deleting an image category automatically unlinks and removes all associated image files from both disk storage and database.

2.5 Work Package 5: React 18 Frontend SPA & Workspaces

- **WP5.1 - Component Architecture:** Modular React 18 SPA built with Vite 6, incorporating Lucide React icon tokens, CSS modular styling, and reactive hooks.
- **WP5.2 - Interactive Dashboard:** Real-time summary counters (Total Documents, Total Storage Footprint formatted dynamically into KB or MB, Active Folder indicator).
- **WP5.3 - Document Workspace:** Folder navigation sidebar, folder creation modal, document card view with file metadata, download action, and delete confirmation dialogs.
- **WP5.4 - Upload Panel:** Interactive upload modal with drag-and-drop support, target folder selector, file size validation, and real-time progress indicators.
- **WP5.5 - Image Workspace:** Category selector, image upload modal, responsive grid view displaying dynamic image previews, file sizes, and deletion controls.
- **WP5.6 - Global Feedback & Notifications:** Toast banner notifications for successes, client validation errors, and network alerts.

2.6 Work Package 6: Subscription Governance & Quota Enforcement

- **WP6.1 - Tier Representation:** Dedicated Plans Page displaying Starter (Free: $0 forever) and Pro ($9/month) comparison matrix.
- **WP6.2 - Daily Rate Limiting:** Enforcement of 3 PDF uploads/day and 5 image uploads/day for Starter tier users using persistent date-keyed session storage.
- **WP6.3 - Upgrade Flow Interceptor:** Automatic trigger of the Pro Upgrade modal when free tier usage limits are reached.

2.7 Work Package 7: Quality Assurance, Security & Deployment

- **WP7.1 - Automated Unit & Integration Testing:** Test coverage validating auth tokens, magic byte rejection, and folder unlinking logic.
- **WP7.2 - Technical Documentation:** Full OpenAPI/Swagger interactive documentation, deployment manuals, and database migration guidelines.
- **WP7.3 - Production Packaging:** Containerization files, environment configuration guides, and storage volume persistence setup.

3. Explicit Out-of-Scope Items (Exclusions)

The following features and services are explicitly excluded from this current phase and may be considered for future roadmap releases (Phase 2):

Exclusion Category	Out-of-Scope Description	Rationale & Future Roadmap Consideration
OCR & Text Extraction	Optical Character Recognition (OCR) to convert scanned PDF images into searchable plaintext.	Requires heavy third-party OCR engines (e.g. Tesseract / Google Vision AI). Planned for Phase 2.
In-Browser PDF Annotation	Interactive PDF viewer allowing highlighting, drawing, notes, and digital form-filling.	Requires integration of complex PDF canvas rendering libraries (e.g. PDF.js canvas overlays). Planned for Phase 2.
Cryptographic e-Signatures	Legally binding digital signature workflows, PKI certificate signing, or DocuSign API integration.	Requires legal compliance frameworks (eIDAS / ESIGN Act) and HSM infrastructure. Planned for Phase 2.

Exclusion Category	Out-of-Scope Description	Rationale & Future Roadmap Consideration
Payment Gateway Integration	Direct automated credit card billing via Stripe, PayPal, or LemonSqueezy.	Current phase implements tier feature gating and simulated upgrade flow. Direct merchant gateway planned for Phase 2.
Native Mobile Apps	Native iOS (Swift) and Android (Kotlin) mobile application packages.	Current frontend is fully responsive across mobile web browsers. Native wrappers planned for Phase 3.
Third-Party Cloud Sync	Bi-directional synchronization with Google Drive, Dropbox, or Microsoft OneDrive.	Requires enterprise OAuth connectors and webhook sync engines. Planned for Phase 3.

4. Roles & Responsibilities (RACI Framework)

The RACI matrix defines governance accountabilities across key delivery activities: Responsible (R), Accountable (A), Consulted (C), Informed (I):

Project Activity / Deliverable	Client Sponsor	Client Product Lead	Solution Architect	Lead Developer	QA Engineer
Requirements Baseline & Sign-Off	A	R	C	I	I
System Architecture & Security Design	I	C	A / R	C	C
Backend API & Auth Implementation	I	I	A	R	C
Frontend UI & Workspace Development	I	C	A	R	C
Security & Quality Verification	I	C	C	C	A / R

Project Activity / Deliverable	Client Sponsor	Client Product Lead	Solution Architect	Lead Developer	QA Engineer
User Acceptance Testing (UAT)	A	R	C	C	C
Production Deployment & Launch	A	C	A	R	C

5. Change Management & Governance Procedure

To ensure budget predictability and timeline adherence, any deviation or enhancement to the agreed scope must adhere to the formal Request for Change (RFC) governance process:

- **Step 1: Submission:** Client submits a written RFC describing the desired functional or architectural change.
- **Step 2: Impact Analysis:** The Solution Architect evaluates technical complexity, dependencies, effort hours, and delivery impact within 3 business days.
- **Step 3: Commercial Authorization:** A formal Change Order detailing revised costs ($85/hr blended rate) and schedule adjustments is presented for client signature.
- **Step 4: Implementation:** Upon written execution of the Change Order, the new scope is scheduled into the development backlog.

6. Scope Acceptance & Contractual Authorization

The signatures below acknowledge that this Scope Document accurately and exhaustively defines the project deliverables, boundaries, and acceptance conditions.

Client Project Sign-Off	Engineering Delivery Sign-Off
Authorized Signatory: _____	Authorized Signatory: _____
Print Name: _____	Print Name: Enterprise Delivery Director
Title: _____	Title: VP of Software Engineering
Date: _____	Date: October 20, 2026